

Introduction to AWS IAM

Identity & Access Management | Users, Groups & Policies | Least Privilege

Course: CYB 222 — Linux Systems Administration & Security (AWS Cloud Module) **Author:** Atif Memon

Portfolio: github.com/atifkaloodi1/cloud-security-labs **Profile:** gravatar.com/atifmemon

✓ **LAB RESULT:** 40 / 40 — full marks on all graded checks (group membership + permission tests for all three users).

Lab Overview & Objectives

AWS Academy — Introduction to AWS IAM • Duration ~40 min

AWS Identity and Access Management (IAM) is the service that controls who can do what in an AWS account. This lab explores pre-created IAM users, groups, and policies, then applies a real-world scenario: granting each user only the access their job requires by placing them in the right group — a hands-on lesson in least privilege.

Objectives

- Explore pre-created IAM users and groups.
- Inspect the IAM policies attached to each group (managed and inline).
- Add users to groups so they inherit the group's permissions.
- Locate and use the IAM sign-in URL.
- Test how policies control access to Amazon S3 and Amazon EC2.

Scenario & Architecture

Mapping users → groups → policies

Three users are each mapped to a group, and each group carries a policy that grants a specific level of access. Permissions flow from the policy, to the group, to the user — users themselves hold no direct permissions.

Lab overview and objectives

This lab will demonstrate:

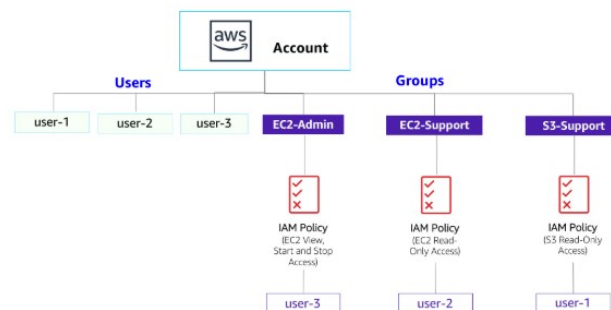


Figure 1 — IAM structure: three users, three groups, and the policy attached to each.

Business scenario

User	Group	Permissions
user-1	S3-Support	Read-only access to Amazon S3
user-2	EC2-Support	Read-only access to Amazon EC2
user-3	EC2-Admin	View, Start, and Stop Amazon EC2 instances

Task 1 — Explore Users and Groups

Inspect the pre-created identities and their policies

1. Open the **IAM** console. Under **Users**, review **user-1**, **user-2**, **user-3** — each has a console password but **no permissions and no group membership** yet.
2. Under **User groups**, inspect the three groups and their attached policies:
 - **EC2-Support** — managed policy **AmazonEC2ReadOnlyAccess** (List/Describe on EC2, ELB, CloudWatch, Auto Scaling).
 - **S3-Support** — managed policy **AmazonS3ReadOnlyAccess** (Get/List on S3).
 - **EC2-Admin** — an **inline policy** granting Describe plus Start and Stop on EC2 instances.

NOTE

Every IAM policy statement has three key parts: **Effect** (Allow or Deny), **Action** (the API calls, e.g. **cloudwatch:ListMetrics**), and **Resource** (the scope, e.g. a specific bucket/instance or ***** for any). Managed policies are reusable and update everywhere at once; inline policies belong to a single user or group for one-off cases.



OPTIONAL SCREENSHOT

IAM console showing the three users and the three groups with their attached policies.

Task 2 — Add Users to Groups

Grant access by group membership, not per-user

1. Add **user-1** to **S3-Support** (User groups → S3-Support → Users → Add users).
2. Add **user-2** to **EC2-Support** using the same steps.
3. Add **user-3** to **EC2-Admin**.
4. Back on **User groups**, confirm each group shows **1** in the Users column.

SECURITY INSIGHT

Assigning permissions through groups rather than to individuals is the scalable, auditable way to do access control: change the policy once and every member inherits it, and onboarding a new hire is a single “add to group” action instead of hand-crafting permissions each time.

NOTE

“Not authorized” messages during this task are expected — the lab account itself has limited permissions and they don't affect completion.



OPTIONAL SCREENSHOT

User groups list showing EC2-Admin, EC2-Support, and S3-Support each with 1 user.

Task 3 — Sign-In and Test Users

Prove that each policy grants exactly the intended access

1. From the IAM **Dashboard**, copy the **Sign-in URL for IAM users** (looks like <https://<account-id>.signin.aws.amazon.com/console>).
2. Open a private / incognito window and sign in as each user in turn to test permissions.

user-1 — S3-Support

Sign in ([Lab-Password1](#)). Can **view S3 buckets and contents**; opening EC2 → Instances returns **You are not authorized to perform this operation**.

user-2 — EC2-Support

Sign in ([Lab-Password2](#)). Can **view the LabHost EC2 instance**, but attempting **Stop instance** fails with a not-authorized error (read-only). S3 shows **You don't have permissions to list buckets**.

user-3 — EC2-Admin

Sign in ([Lab-Password3](#)). Selecting [LabHost](#) and choosing **Stop instance succeeds** — the instance enters the stopping state.

EXPECTED RESULT

The three tests together prove the policies work as designed: read-only groups can look but not touch, the admin group can act, and access to one service never leaks into another. Deny-by-omission is the default — a user gets nothing unless a policy explicitly grants it.



OPTIONAL SCREENSHOT

user-2 receiving a not-authorized error when attempting to stop the instance (read-only).



OPTIONAL SCREENSHOT

user-3 successfully stopping the LabHost instance (admin permissions).

Security Insights & Key Takeaways

Notes for the CYB 222 capstone article

- **Least privilege in practice.** Each user receives only the access their role needs — the foundational security principle, demonstrated end to end.
- **Groups scale access control.** Permissions attach to groups; users inherit them. One policy change propagates to every member.
- **Managed vs inline policies.** Managed policies are reusable and centrally updated; inline policies are bound to a single identity for one-off needs.
- **Effect / Action / Resource.** The anatomy of every policy statement — what's allowed or denied, which API calls, and over which resources.
- **Deny by default.** With no policy, a user can do nothing; access exists only where explicitly granted. Read-only vs admin is the difference between Describe and Start/Stop.
- **Users, roles, and federation.** IAM also supports roles (assumable identities) and federated sign-in — the basis for cross-account and enterprise SSO access without per-person users.

Lab Result

AWS Academy submission report

All graded checks passed with a perfect score — group membership for all three users plus each permission test.

Total score	40/40
TASK 2a - Added user-1 to S3-Support group	5/5
TASK 2b - Added user-2 to EC2-Support group	5/5
TASK 2c - Added user-3 to EC2-Admin group	5/5
TASK 3a - user-1 logged in	5/5
TASK 3b - user-2 logged in	5/5
TASK 3c - user-2 ec2 stop instance attempt	5/5
TASK 3d - user-3 logged in	5/5
TASK 3e - user-3 EC2 stop instance attempt	5/5

Submission report — Total score 40 / 40.

Atif Memon • [cloud-security-labs](#) • gravatar.com/atifmemon